

Server-side topic

Klasa napada: Business logic vulnerabilities

Definicija klase: Business Logic Vulnerabilities (ranjivosti poslovne logike) predstavljaju propuste u dizajnu aplikacije gde napadač može manipulirati pravilima i tokovima procesa koje je programer definisao. Za razliku od tehničkih bugova (kao što je SQL injection), ovde aplikacija tehnički ispravno izvršava kod, ali logika tog koda dozvoljava zloupotrebu.

Uticaj: Iskorištavanje ovih ranjivosti može dovesti do direktne finansijske štete (npr. kupovina proizvoda po nižoj ceni), neovlašćenog pristupa podacima drugih korisnika, zaobilaženja sigurnosnih kontrola ili preuzimanja administrativnih privilegija.

Uzroci ranjivosti: Osnovni uzrok je često "preveliko poverenje" u klijentsku stranu (browser). Aplikacija pretpostavlja da korisnik ne može promeniti podatke koje šalje, pa server ne vrši dovoljnu validaciju tih podataka (npr. ne proverava cenu u bazi podataka već veruje ceni koju je brauzer poslao).

Kontramere:

1. **Server-side validacija:** Najbitnije pravilo – nikada ne veruj podacima koji dolaze od korisnika. Sve cene, količine i dozvole se moraju proveravati isključivo na serveru (u bazi podataka).
2. **State management:** Implementacija sigurnog praćenja sesija i stanja korisnika tako da se ključni parametri ne mogu menjati kroz običan HTTP request.
3. **Least privilege princip:** Korisniku se sme dozvoliti pristup samo onim funkcijama koje su mu neophodne za obavljanje trenutnog zadatka.
4. **Audit log:** Vođenje dnevnika svih kritičnih operacija kako bi se sumnjive transakcije mogle kasnije identifikovati.